

Supply-Chain Configuration Weakness — Dependabot Cooldown

Assessment Identifier: **WS-STA-10** | Assessment Type: **Static** | Date: **September 08, 2026**

Severity: MEDIUM	CVSS: 4.0	CWE: CWE-829
OWASP: A08	WASC ID: N/A	Confidence: Configuration finding — verify policy requirement
Target / Component: .github/dependabot.yml	Affected URL: https://github.com/worldmonitor/worldmonitor/blob/main/.github/dependabot.yml	Parameter: Dependabot cooldown configuration

1. Description

Static analysis identified a dependency-management configuration weakness: the expected Dependabot cooldown configuration is absent. This is a security configuration finding rather than a direct exploit by itself.

2. Steps to Reproduce

1. Open .github/dependabot.yml.
2. Review dependency update configuration.
3. Confirm the expected cooldown setting is absent.
4. Review the dependency update workflow and approval process.

3. Controlled Proof of Concept

Safe Proof of Concept:

No exploit is required. The PoC is configuration evidence showing the dependency update policy and absence of the expected cooldown control.

4. Business & Security Impact

Rapid dependency updates can increase supply-chain risk if a newly published package version is compromised or introduces an unexpected security issue.

5. Remediation Recommendations

Primary Fix: Configure an appropriate dependency update cooldown and review policy. Maintain dependency review, lockfiles, vulnerability monitoring, automated testing, and controlled update procedures.

1. Establish a minimum cooldown delay (e.g., 3-7 days) for non-critical dependency updates to allow public malicious package detection.
2. Mandate branch protection, CI automated test passes, and manual peer review on all automated pull requests.
3. Lock dependency versions using package-lock.json and integrate automated vulnerability scanning (npm audit / Snyk).

6. Evidence & Validation

Evidence Type: Textual / Static Source Analysis

This finding was identified through static analysis of repository source code and configuration files. Per assessment requirements, no simulated runtime screenshots or dynamic PoC captures are applicable. Verification must be performed via source code review and static analysis tool verification.

Authorization & Safety Compliance: *This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.*